



IDEAS MADE TO MATTER | CYBERSECURITY

How to build a culture of cybersecurity

Technology and training are not enough to safeguard companies against today's litany of cybersecurity attacks. Here's how to infuse safe behavior into corporate culture.

by Beth Stackpole

Mar 15, 2022

Share ↗

At a large bank, the CEO kicks off every all-staff meeting with a cybersecurity story, whether recounting a personal experience or discussing relevant, newsworthy incidents.

At another company, a former marketing manager parlays her messaging skills into creating campaigns that inform and engage employees on cybersecurity readiness and responsibility. Elsewhere, companies underscore the importance of cybersecurity by formally evaluating employees and doling out rewards or consequences based on their actions.



Work smart with our Thinking Forward newsletter

*Insights from MIT experts,
delivered every Tuesday morning.*

☐

Yes, I'd also like to subscribe to
the AI at Work newsletter

Email:

SIGN UP



These initiatives are all aimed at the same goal: nurturing a culture of cybersecurity that tasks every member of an organization with embracing attitudes and beliefs that drive secure behaviors.

Investment in cybersecurity technologies and training and awareness programs has soared the last few years as the threat landscape grows. Yet those efforts don't go far enough in fully mitigating cybersecurity risks, according to Keri Pearlson, executive director of Cybersecurity at MIT Sloan, or CAMS. This is because the weak link is typically people and behavior — a problem that is only resolved through a combination of technology investment and culture change.

At the EmTech CyberSecure conference hosted by MIT Technology Review, Pearlson explained how and why companies should implement managerial mechanisms that change people's values, attitudes, and beliefs about cybersecurity at every organizational level.

"We put so many resources into 'locking up' using technology that we forget about the back doors in the organization, and that's usually people," said Pearlson, who has a doctorate in business administration with a focus on management information systems. "We need a culture of cybersecurity because you can't tell everyone everything they need to do. You need them to understand that organizational safety is part of what they need to do in today's world."

Make cybersecurity part of the organization's fabric

Companies are under pressure to step up cybersecurity given the scope and scale of what's at stake. Cybersecurity Ventures projects global cybercrime costs to grow by 15% per year over the next five years, reaching \$10.5 trillion annually by 2025.



85%

Share 

The human factor was involved in more than 85% of data breaches, according to the 2021 Verizon Data Breach Investigations Report.



In 2021, the average data breach cost soared to \$4.24 million, the highest in the 17-year history of IBM's Cost of a Data Breach report. The common theme in these and other cybersecurity reports is that the human element is by far the largest risk. In fact, the 2021 Verizon Data Breach Investigations Report found the human factor was involved in over 85% of breaches, whether that entailed falling for a phishing attack, making bad decisions that lead to malware infections, or using easily decipherable passwords.

That's where a cybersecurity culture comes into play, Pearson said. It's not just about giving people a playbook on how to avoid phishing emails or providing password management training. Rather, it's infusing safety into the organizational fabric so every employee is constantly reminded of their role and responsibility to keep the organization safe.

Companies with the least mature cybersecurity culture offload the work and responsibility to the technology department, generally under the auspices of the chief information officer or chief information security officer, Pearson said.

More mature organizations reinforce cybersecurity culture at three levels:

Leadership level: Like the CEO who talks about security in all-company meetings, leaders prioritize cybersecurity, making it clear to everyone in the organization that it's an intrinsic part of corporate values. While the CIO or CISO is at the helm of cybersecurity strategy and initiatives, non-cyber executives, including the board of directors, are visibly aligned with the mission and put the proper behaviors on display.

Group level: Cybersecurity issues begin to permeate discussions among employees and seep into how teams work together. Watercooler conversations or Slack and Zoom meetings include cybersecurity-related topics, and non-technical business groups begin to seek out guidance on how they can be more

secure. The group-level activities show that cybersecurity is important to the team and that in turn drives more secure behaviors, Pearson said.

Individual level: Employees gain a general awareness of the kinds of threats possible and feel empowered to take action if they encounter something suspicious. Moreover, they know exactly what to do in the event of an incident — for example, how and where to report a phishing email incident or flag a suspicious person walking out the door with a laptop.

EXECUTIVE EDUCATION: CYBERSECURITY LEADERSHIP FOR NON-TECHNICAL EXECUTIVES 

Drive culture change with these four steps

So what can be done to drive organizational change and foster a cybersecurity culture that engages across all levels? Pearson made the following recommendations, based on CAMS research:

Make it someone's job to be the 'culture owner.' This isn't necessarily the CIO or CISO, but a non-technical executive who specifically owns the actions necessary to change behavior and drive values, attitudes, and beliefs. One culture owner created campaigns that resonated with employees, including using famous movie titles to reflect important cybersecurity messages. Other training programs incorporated fun icons and famous memes to drive engagement and encourage discussion among employees.

RELATED ARTICLES

[11 lessons from the Timehop data breach](#)

[Deepfakes, explained](#)

[8 non-technical ways to improve your company's cybersecurity](#)

Use language that resonates. If you want to foster change, it's important to communicate in terms workers understand. One culture owner at a major insurance company determined that the term cybersecurity wasn't connecting with employees. The messaging was changed to "protect our data and systems," an objective team members clearly understood. "In their world, data was king, so everyone in the organization understood the need to protect data," Pearson said. "That one small change in

terms made a huge difference in what people had to do and in building a culture of cybersecurity."

Messaging is also critical to building engagement. An insurance provider CAMS studied built a multi-channel communications campaign to disseminate cybersecurity information, including videos, digital displays, blogs, alerts, emails, postcards, events, and training to connect with employees on multiple fronts.

Make cybersecurity part of formal employee evaluation. With formal evaluation of cybersecure behaviors, employees know what is expected of them. When coupled with rewards and consequences, this gives organizations the best chance of driving behavior and culture change. At one insurance provider, if an employee failed a phishing exercise too often, it was reflected in their performance review. It was also noted if an employee went above and beyond their position to help colleagues better understand why it was important to create a stronger culture of cybersecurity and data protection.

There should also be consequences for undesired behavior. In one company CAMS studied, those that failed phishing exercises once got referred to refresher training, while a second infraction meant a meeting with a direct manager. The third failure led to a referral to HR, and the fourth time, internet privileges were lost. Any additional incidents resulted in termination.

Conduct tabletop exercises and fire drills. Pearlson encouraged organizations to simulate, either through scenario planning or tabletop exercises, what should happen in the event of a real breach. “You don’t want the first time you’ve thought about a cyberattack to be in the middle of a cyberattack,” she said. “You want to be prepared.”

READ NEXT: HOW TO RESPOND TO A RANSOMWARE ATTACK →



FOR MORE INFO

Sara Brown

Senior News Editor and Writer

sbrown1@mit.edu

FIND US

MIT Sloan School of Management

100 Main Street

Cambridge, MA 02142

617-253-1000

©2026 MIT SLOAN SCHOOL OF MANAGEMENT